BRITTLE POLICY (OVERLY BROAD)

Here’s the policy that caused the problem:

```
permit(
    principal in Employee,        // grants to all employees
    action == Action::"doc:view",
    resource in Document        // all documents
);
```

On the surface, this seems okay: employees should be able to view documents. However, because it applies to all employees and all documents, it allowed access well beyond what was intended. Interns and others had no reason to see documents outside of the ones they needed for their work.

IMPROVED POLICY (LEAST PRIVILEGE)

Here’s a version that restricts the scope to limit access:

```
permit(
    principal,
    action == Action::"doc:view",
    resource in Document::"alpha/*"        // just project docs
)
when{
    Project::"alpha".members.contains(principal) // only project mem
bers
};
```

By limiting access to the project container, only employees who genuinely need it are granted access. Restricting policies to the smallest possible group prevents accidental exposure and upholds the principle of least privilege.

Figure 10.2 illustrates how ACME’s initial “all employees” policy granted access too broadly, compared to the corrected least-privilege policy.